

Política de Privacidade (Modelo)

LGPD Art. 9º/41 — pendente de preenchimento institucional

Ciclartech · Plataforma de Gestão de Ativos Assistivos

Política de Privacidade — [NOME DO TENANT/ORGANIZAÇÃO]

Este documento é um modelo técnico, gerado a partir do que o sistema efetivamente coleta, processa e retém — não é um parecer jurídico. Os campos entre [COLCHETES] precisam ser preenchidos por **cada tenant** antes da publicação. Recomenda-se revisão por advogado especializado em proteção de dados antes de publicar.

Decisão institucional adotada: cada tenant é o **controlador** dos dados dos seus próprios beneficiários (a Ciclartech é apenas a **operadora** da plataforma que processa esses dados por conta do tenant — distinção do Art. 5º, VI e VII). Por isso o Encarregado (DPO) é configurado **por tenant**, não um único DPO da Ciclartech para toda a plataforma. Quem preenche é o **Admin do próprio tenant**, em `/app/encarregado/` (`core/views_encarregado.py` , `Tenant.dpo_nome / dpo_email / dpo_telefone` — `core/models.py`) — só o próprio tenant sabe quem, na organização dele, deve responder por isso. O Owner também pode editar em `/owner/contratos/<id>/editar/` como canal de suporte, mas o preenchimento pelo próprio tenant é o fluxo esperado. Estes campos podem ser usados para gerar esta política automaticamente por tenant, em vez de um documento único estático.

Última atualização: [DATA] **Versão:** 1.0

1. Quem trata os seus dados (Controlador)

Razão social: [RAZÃO SOCIAL] **CNPJ:** [CNPJ] **Endereço:** [ENDEREÇO] **Contato:** [E-MAIL DE CONTATO GERAL]

2. Encarregado pelo Tratamento de Dados Pessoais (DPO)

Nos termos do art. 41 da Lei nº 13.709/2018 (LGPD), esta organização designa como Encarregado(a):

Nome: [NOME DO ENCARREGADO — cadastrado em `Tenant.dpo_nome`] **E-mail:** [E-MAIL DO DPO — `Tenant.dpo_email`] **Telefone:** [TELEFONE, OPCIONAL — `Tenant.dpo_telefone`]

O Encarregado é o canal de comunicação entre o controlador (esta organização, não a Ciclartech — ver nota institucional no topo deste documento), os titulares dos dados e a Autoridade Nacional de Proteção de Dados (ANPD), e pode ser contatado para qualquer dúvida ou solicitação relativa a esta política.

3. Quais dados coletamos

A plataforma [NOME DO SISTEMA] processa dois grupos de titulares:

3.1. Dados de usuários do sistema (equipe da organização)

Nome, e-mail, usuário de acesso e senha (armazenada com hash Argon2id, nunca em texto plano), papel/função na organização e unidade(s) de atuação.

3.2. Dados de beneficiários/pacientes/clientes

Coletados no cadastro da pessoa para quem um ativo (equipamento, item) é destinado:

- **Identificação:** nome completo, CPF ou CNPJ, RG, data de nascimento.
- **Contato:** telefone, WhatsApp, e-mail, endereço, bairro, cidade, CEP.
- **Contato de emergência:** nome, telefone e parentesco de uma pessoa de referência.
- **Documentos anexados:** cópia de RG, CPF, comprovante de residência e, quando aplicável, **laudo médico ou receita médica**.

Dado sensível (LGPD art. 5º, II): laudos e receitas médicas constituem dado pessoal sobre saúde. Recebem tratamento reforçado (ver seção 6).

3.3. Dados coletados automaticamente

Registros de acesso e ação no sistema (quem fez o quê, quando) para fins de auditoria e segurança — ver seção 8. Não coletamos cookies de rastreamento de terceiros nem dados de navegação para fins publicitários.

4. Para que usamos os seus dados (finalidade)

Finalidade	Dados envolvidos
Gestão do empréstimo/uso de ativos (equipamentos)	Identificação, contato, histórico de movimentação
Comunicação sobre prazos de devolução (WhatsApp/e-mail)	Contato
Comprovação de posse e condição do equipamento	Fotos, assinatura do termo
Justificativa clínica do empréstimo, quando aplicável	Laudo/receita médica
Segurança e prevenção a fraude	Trilha de auditoria (login, alterações)
Cumprimento de obrigação legal/prestação de contas	Histórico de movimentação patrimonial

Não utilizamos os dados para publicidade, venda a terceiros, ou qualquer finalidade além das listadas acima.

5. Base legal do tratamento

Cada titular tem uma base legal declarada explicitamente no cadastro (LGPD art. 7º para dado comum, art. 11 para dado sensível), entre:

- **Consentimento do titular** — pode ser revogado a qualquer momento (ver seção 7).
- **Obrigação legal ou regulatória.**
- **Execução de política pública**, quando o serviço é prestado por entidade pública ou conveniada.
- **Tutela da saúde**, para dados clínicos (laudo/receita).
- **Execução de contrato**, quando o empréstimo decorre de uma relação contratual (ex.: locação).

6. Como protegemos os seus dados

- Senhas nunca são armazenadas em texto plano (hash Argon2id).
- Conexão sempre criptografada (HTTPS/TLS).
- Cada organização (tenant) só acessa os seus próprios dados — isolamento técnico reforçado em múltiplas camadas.
- Acesso interno é restrito por função: cada pessoa da equipe só vê o que é necessário ao seu papel e à(s) unidade(s) em que atua.
- Documentos anexados (RG, laudo, receita) nunca são expostos por link direto — todo acesso passa por autenticação e é registrado.
- Uploads são verificados quanto ao tipo real do arquivo, não apenas pelo nome, para impedir arquivos disfarçados.
- Toda ação sobre dado pessoal fica registrada em trilha de auditoria imutável (não pode ser editada ou apagada, nem pela própria equipe técnica).

7. Seus direitos como titular (LGPD art. 18)

Você pode, mediante solicitação ao Encarregado (seção 2):

- **Confirmar e acessar** os dados que temos sobre você.
- **Solicitar cópia** dos seus dados em formato estruturado (portabilidade).
- **Corrigir** dados incompletos, inexatos ou desatualizados.
- **Revogar o consentimento**, quando essa for a base legal do seu tratamento — a revogação não apaga o histórico de empréstimos já realizado, que continua amparado por outra base legal (obrigação legal de prestação de contas).
- **Solicitar a eliminação** dos seus dados pessoais. Na prática, isso remove nome, CPF, contato e demais dados identificáveis, e apaga fisicamente laudos/receitas anexados — mas preserva, de forma anônima (sem identificação possível), o histórico de qual equipamento foi emprestado e devolvido, porque esse registro cumpre uma finalidade

de prestação de contas patrimonial distinta da sua identificação pessoal (LGPD art. 16, I).

- **Solicitar informação** sobre com quem compartilhamos seus dados — hoje não compartilhamos dados de titulares com terceiros fora da prestação do serviço.

Prazo de resposta: em até 15 dias, salvo prorrogação justificada comunicada ao titular.

8. Retenção e descarte

- Dados de beneficiários são mantidos enquanto durar a relação com a organização, ou até solicitação de eliminação (seção 7).
- Registros de auditoria (quem acessou o quê) são retidos por até 24 meses, após os quais são expurgados automaticamente por rotina periódica.
- Documentos anexados (RG, laudo, receita) são removidos definitivamente do armazenamento no momento da eliminação solicitada pelo titular, não apenas desvinculados do cadastro.

9. Compartilhamento com terceiros

[PREENCHER: descrever se há compartilhamento com operadoras de infraestrutura (ex.: provedor de nuvem, provedor de envio de WhatsApp/e-mail) e sob que finalidade/garantias contratuais. Ex.: "Utilizamos os serviços de nuvem [Supabase/AWS] para armazenamento técnico dos dados, sob contrato que exige confidencialidade e não permite uso dos dados para finalidade própria."]

10. Alterações desta política

Esta política pode ser atualizada para refletir mudanças no sistema ou na legislação. A data de "última atualização" no topo deste documento indica a versão vigente. Mudanças relevantes serão comunicadas aos titulares pelos canais de contato disponíveis.

11. Como falar com a gente

Dúvidas, solicitações de direitos do titular ou denúncias relacionadas a esta política: [E-MAIL DO DPO] ou [CANAL DE ATENDIMENTO, SE HOUVER].

Nota técnica para a equipe de implantação

Este documento cobre as exigências mínimas da LGPD para publicação: identificação do controlador (art. 9º), designação de encarregado (art. 41) e informação clara sobre tratamento (art. 9º, incisos I a VI).

Antes de publicar para um tenant real:

1. O Admin do próprio tenant preenche o Encarregado em `/app/encarregado/` (campos `dpo_nome / dpo_email / dpo_telefone` no model `Tenant`) — fluxo esperado, já que só o tenant sabe quem deve responder por isso. O Owner também pode editar em `/owner/contratos/<id>/editar/` como canal de suporte; a tela de detalhe do tenant (`/owner/contratos/<id>/`) mostra um aviso enquanto isso não for feito.
2. Preencher os demais campos `[ENTRE COLCHETES]` (razão social, CNPJ, endereço) com dados reais do tenant.
3. Revisar com advogado especializado em proteção de dados antes de publicar.
4. Publicar o documento final em local acessível ao titular (ex.: rodapé do sistema, link no formulário de cadastro de beneficiário) — hoje não há link para esta política em nenhuma tela do sistema, e o texto ainda é estático por tenant (não gerado automaticamente a partir do `Tenant.dpo_nome` cadastrado) — próximo passo natural de evolução, não incluído nesta entrega.